Windows Access Token

Description

Un **Windows Access Token** è un oggetto fondamentale nel sistema operativo Windows che rappresenta un'istanza di autorizzazione per un utente o un processo. Questi token sono utilizzati dal sistema operativo per determinare l'accesso alle risorse e per applicare politiche di sicurezza. Ogni volta che un utente o un processo tenta di accedere a una risorsa, Windows verifica il relativo access token per determinare se l'azione richiesta è permessa.

Cos'è un Access Token?

Un **Access Token** è una struttura di dati che contiene informazioni cruciali su un utente o un processo, come:

- L'identità dell'utente (inclusi i gruppi di appartenenza).
- I privilegi e i diritti di accesso dell'utente o del processo.
- Le informazioni sul contesto di sicurezza associato all'utente o al processo.

In sostanza, un access token è un "pass" che definisce cosa può e cosa non può fare un utente o un processo su un sistema Windows.

Struttura di un Access Token

Un access token contiene diverse informazioni e può essere suddiviso in vari componenti:

1. **Identità dell'utente**:
    - L'access token contiene l'**ID di sicurezza (SID)** dell'utente, che è un identificatore univoco assegnato a ogni utente, gruppo e processo in Windows.
    - Include anche gli **SID dei gruppi** a cui l'utente appartiene. Questo permette di sapere a quali gruppi di accesso l'utente è associato, come gli amministratori, utenti standard, ecc.
2. **Informazioni sul privilegio**:

- I privilegi sono diritti speciali che permettono a un utente o a un processo di eseguire operazioni sensibili (ad esempio, modificare l'orologio di sistema o cambiare l'ora). Ogni privilegio è rappresentato da un SID.
- L'access token contiene una lista dei privilegi assegnati all'utente, come **SeBackupPrivilege** (per il backup) o **SeShutdownPrivilege** (per lo spegnimento del sistema).

3. **Diritti di accesso**:
   - Un access token può anche contenere un **ACL (Access Control List)** che determina quali diritti di accesso un processo o un utente ha su specifici oggetti nel sistema (file, cartelle, registry keys, ecc.).
   - Questo è il principale meccanismo attraverso cui Windows determina se un utente o un processo può leggere, scrivere o eseguire determinate azioni su un oggetto.
4. **Contesto di sicurezza**:
   - L'access token contiene informazioni sul **contesto di sicurezza** dell'utente, ad esempio se l'utente è loggato in modalità interattiva, remota, come amministratore, ecc.
   - Include anche un **timestamp** che indica quando l'accesso è stato creato, utile per la gestione dei permessi.
5. **Tipo di token**:
   - Esistono diversi tipi di access token, come:
     - **Primary Token**: Assegnato al processo principale di un utente, come quando un utente si autentica su un computer.
     - **Impersonation Token**: Utilizzato quando un processo assume l'identità di un altro processo o utente per eseguire azioni a nome di quell'utente.
     - **Default Token**: Assegnato a processi che non hanno un token specifico, ma che operano con i privilegi predefiniti di un sistema.

Creazione di un Access Token

Gli access token vengono creati dal sistema operativo in vari momenti. I più comuni includono:

1. **Autenticazione dell'utente**:
    - Quando un utente si autentica (ad esempio, inserendo una password), Windows crea un access token che rappresenta quella sessione dell'utente. Questo token è associato al processo di login e contiene le informazioni sull'utente e i suoi privilegi.
2. **Avvio di un processo**:
    - Ogni volta che viene avviato un nuovo processo, il sistema operativo associa a quel processo un access token. Il token può essere ereditato dal processo genitore (ad esempio, se un utente avvia un'applicazione, il processo dell'applicazione avrà lo stesso access token dell'utente).
3. **Impersonificazione**:
    - Un processo con sufficienti privilegi può usare l'accesso impersonale (impersonation) per agire con i privilegi di un altro utente o processo. In questo caso, viene creato un access token impersonato.

Funzionamento degli Access Token

Gli access token sono utilizzati dal **Windows Security Subsystem** per determinare se un'operazione è consentita. Quando un utente o un processo tenta di accedere a una risorsa, il sistema operativo confronta l'access token con le **Access Control Lists (ACL)** associate alla risorsa. Le ACL definiscono chi può fare cosa sulla risorsa (ad esempio, chi può leggere, scrivere o modificare un file).

1. **Autenticazione**:
    - Quando un processo cerca di accedere a una risorsa, il sistema controlla il SID dell'access token dell'utente rispetto all'ACL della risorsa.
    - Se il SID dell'utente è presente nell'ACL con i permessi appropriati, l'accesso è consentito; altrimenti, viene negato.
2. **Esecuzione di Privilegi**:
    - Gli access token determinano anche se un processo ha i privilegi necessari per eseguire operazioni sensibili. Ad esempio, un processo che

cerca di fare un'operazione che richiede privilegi elevati (come modificare la configurazione di sistema o installare un driver) dovrà avere un privilegio associato nel suo access token.

3. **Impersonificazione**:
    - Un processo può usare impersonificazione per agire come se fosse un altro utente. Quando un processo impersonifica un altro utente, viene associato all'access token di quell'utente e può agire con i privilegi e i permessi di quell'utente.

Come gli Access Token sono Gestiti

I **Security Identifiers (SID)** contenuti nell'access token sono parte integrante della gestione della sicurezza. Ogni SID è unico per un dato sistema e per ogni account utente o gruppo. Questi SID vengono usati dalle **Access Control Lists (ACL)** per determinare i diritti di accesso.

Inoltre, Windows offre delle **funzioni API** che consentono di manipolare gli access token, come:

- `OpenProcessToken`: Apre l'access token di un processo.
- `GetTokenInformation`: Recupera informazioni dettagliate sull'access token.
- `SetTokenInformation`: Modifica informazioni nell'access token (ad esempio, aggiungendo privilegi).

Sicurezza e Access Token

Poiché gli access token controllano l'accesso alle risorse e la possibilità di eseguire operazioni privilegiate, è fondamentale che vengano gestiti con attenzione:

- **Elevazione dei privilegi (Privilege Escalation)**: Se un processo o utente riesce a ottenere un access token con privilegi più elevati, potrebbe eseguire operazioni che altrimenti gli sarebbero vietate.
- **Attacchi come Pass-the-Token**: In attacchi avanzati come **Pass-the-Token**, un attaccante cerca di rubare o impersonare un access token valido per ottenere l'accesso a risorse privilegiate.

Windows fornisce varie misure di sicurezza per proteggere gli access token, come la crittografia dei token in memoria e il controllo delle modalità in cui i processi possono impersonificare altri utenti.